AssetTrust v0.61

Audit-ledger row-level security | Engineering and release assessment

Release decision: NO-GO — development checkpoint only. No live PostgreSQL or end-to-end deployment approval.

1. Implemented change

This checkpoint adds PostgreSQL **ENABLE + FORCE ROW LEVEL SECURITY** to **audit_events** using append-only, tenant-matched SELECT and INSERT policies in forward-only migration **026_audit_events_rls.sql**. The existing runtime database role still has UPDATE/DELETE grants revoked.

- Audit writes set transaction-local organization context before reading the hash-chain head and inserting an event.
- Audit list/verification and local-proof routes read inside tenant-scoped transactions.
- The trusted platform-admin bootstrap scopes its audit append transaction.
- Production startup checks eight RLS-protected tables and rejects elevated or table-owner runtime roles.
- A guarded two-organization PostgreSQL test is prepared using separate operator and restricted runtime logins.

2. Verification evidence

Check	Observed result
New v0.61 tests	16 / 16 passed — includes mocked service behavior and fail-closed test guards
Historical and current version suites	59 / 59 passed across recorded runs; individual logs in source ZIP
Migration fingerprint integrity	26 / 26 fingerprints matched; migrations 001–025 unchanged from v0.60
Architecture, syntax, CI and smoke	Passed; 104 TS/TSX source files pass syntax/transpilation (not full build)
Current-source secrets	0 high-confidence findings across 2,787 files (not a history scan)

3. Tenant RLS source coverage

Eight tables have RLS policies in source: audit events, assets, verification cases, case evidence, documents, and three PDF-layout administration tables. **This is not complete tenant isolation across the database.** A broad inventory of sensitive operational, account, membership and admin tables remains to be addressed.

Release gaps and required validation

Evidence-centered release controls | AssetTrust v0.61

4. Executed checks that did not pass

Required validation	Recorded outcome
Clean dependency install	BLOCKED: genuine package-lock.json is absent; npm ci failed
Full API / frontend compilation	FAILED: installed NestJS, PostgreSQL and Node type dependencies are missing
Supervised release preflight	BLOCKED: authentic npm lockfile missing
PostgreSQL audit RLS live contract	NOT RUN LIVE: refused to start without approved disposable database and explicit consent

5. Outstanding production risks

• The new audit RLS policies have not yet been applied or tested on a real disposable PostgreSQL server. Privilege and transaction behavior remain unverified in a live database.

• Missing authentic lockfile/dependencies prevent a successful compiled release. Full test coverage, HTTP/two-API workflows and authenticated browser journeys are not established.

• Real ClamAV clean/malicious tests, deployment TLS/HSTS, secret history scan, backup-and-restore validation and independent penetration testing remain incomplete.

• The local audit hash chain is neither independent blockchain anchoring nor an official land-registry certification. Privileged DB operators can still bypass or alter records.

• A tenant-scoped database setting is defense in depth, not a substitute for input validation, parameterized queries, strong authentication and least-privilege access.

6. Safe rollout and next milestone

Do **not** apply migration 026 while an older API still serves unscoped audit queries. First produce a restore-tested backup and rehearse the change in staging. Then drain the old API, deploy the updated application and migration as one controlled release, validate the restricted runtime role and two-organization behavior, and run end-to-end workflows before any production cutover.

On Kali Linux, follow **V61_KALI_VALIDATION.md**: create and review a genuine npm lockfile, run npm ci and both builds, apply and verify migrations in a dedicated disposable PostgreSQL database, then execute the consent-gated audit RLS and multi-API tests.

Final disposition: NO-GO for production, customer land records and commercial transactions.